

Procédure de configuration

Nomad-Security

VPN WireGuard, Reverse Proxy et MFA pour accès distant sécurisé

Organisation	Nomad-Security (accès distants sécurisés pour collaborateurs nomades)
Lien avec R01	Authentification fédérée à l'Active Directory de Resilience-IT
Composants	pfSense, Ubuntu Server, WireGuard, Docker, Nginx Proxy Manager, Authelia
Réseaux	VPN 10.0.0.0/24 — LAN 192.168.20.0/24

1. Contexte et architecture cible

Resilience-IT héberge des données critiques et doit permettre à ses collaborateurs nomades d'accéder en sécurité aux applications internes (GLPI, partages, intranet) depuis l'extérieur du réseau de l'entreprise. La réalisation Nomad-Security répond à ce besoin en combinant trois briques complémentaires sur une seule VM passerelle, srv-gw-sec (Ubuntu Server, 192.168.20.30) :

- VPN WireGuard : tunnel chiffré établi entre le poste du collaborateur et le réseau interne, garantissant la confidentialité des échanges sur un réseau public.
- Reverse Proxy (Nginx Proxy Manager) : point d'entrée HTTPS unique qui publie les applications internes (GLPI) sans les exposer directement, et gère la terminaison SSL.
- Portail d'authentification (Authelia) : impose une double authentification (mot de passe Active Directory + code TOTP) avant tout accès aux ressources sensibles, et assure ensuite une connexion automatique (SSO) sur les applications protégées.

Cette réalisation s'appuie directement sur l'annuaire Active Directory déployé dans la réalisation Resilience-IT (R01) : les comptes utilisateurs et le compte de service applicatif (svc-authelia) y sont déjà créés et utilisés ici via LDAP.

1.1. Schéma de principe des flux

- Poste nomade → tunnel WireGuard (UDP 51820) → srv-gw-sec
- srv-gw-sec → LAN interne (192.168.20.0/24) : Active Directory (DNS/LDAP), GLPI
- Navigateur → HTTPS (443) → Nginx Proxy Manager → vérification Authelia → GLPI

Le tableau ci-dessous récapitule les adresses et rôles des éléments impliqués.

srv-gw-sec	192.168.20.30	Passerelle VPN / Reverse Proxy / MFA
SRV-GLPI	192.168.20.20	Application GLPI (Apache, port 80)
SRV-AD-01	192.168.20.10	Active Directory, DNS, LDAP
pfSense (WAN)	172.16.1.33	Pare-feu, NAT entrant

2. Configuration du pare-feu pfSense

Le pare-feu pfSense constitue la frontière entre Internet et le réseau interne de l'entreprise. Il doit autoriser uniquement le trafic strictement nécessaire au fonctionnement du VPN, tout en bloquant toute autre tentative d'accès depuis l'extérieur. Trois opérations sont nécessaires : la création d'alias pour faciliter la lecture des règles, l'ouverture du port WireGuard via une règle de NAT, puis la définition des règles de filtrage par interface.

2.1. Création des alias

Les alias permettent de nommer des adresses IP, ports ou réseaux afin de rendre les règles de pare-feu plus lisibles et plus faciles à maintenir (Firewall > Aliases).

SERVEUR_GW_SEC	(Host)	192.168.20.30	Serveur VPN + Authelia + NPM
WG_PORT	(Port)	51820	Port WireGuard (UDP)
WG_NETWORK	(Network)	10.0.0.0/24	Réseau VPN WireGuard
DNS_AD	(Host)	192.168.20.10	Serveur DNS Active Directory
RFC1918	(Network)	10/8, 172.16/12, 192.168/16	(anti-spoofing WAN)

2.2. Règle de NAT (Port Forward)

Cette règle redirige le trafic UDP entrant sur le port 51820 de l'interface WAN vers l'adresse interne de srv-gw-sec, permettant aux clients distants d'initier le tunnel WireGuard (Firewall > NAT > Port Forward).

```
Interface : WAN          Protocole : UDP
Destination port : 51820 → Redirect vers 192.168.20.30:51820
Filter rule association : Add associated filter rule
Description : NAT_WireGuard_Nomad
```

2.3. Règles de filtrage par interface

Chaque interface (WAN, LAN, WG) reçoit des règles spécifiques selon le principe du moindre privilège : seul le trafic explicitement nécessaire est autorisé, tout le reste est implicitement bloqué.

```
WAN : Block    RFC1918 → Any          (anti-spoofing)
WAN : Pass UDP  Any → WAN_Address:WG_PORT (ouverture VPN)
LAN : Pass TCP  LAN_Net → SERVEUR_GW_SEC:80,443 (accès web interne)
LAN : Pass UDP  LAN_Net → SERVEUR_GW_SEC:51820 (clients internes → WG)
WG : Pass Any   WG_NETWORK → LAN_Net      (accès VPN → LAN)
WG : Pass Any   WG_NETWORK → DNS_AD:53     (résolution DNS interne)
WG : Block     WG_NETWORK → Any          (blocage final, sécurité)
```

La règle de blocage final sur l'interface WG empêche un client VPN compromis d'atteindre des ressources non explicitement autorisées au-delà du LAN et du DNS, conformément au principe de moindre privilège.

3. Déploiement de la VM srv-gw-sec

La passerelle est hébergée sur une machine virtuelle Ubuntu Server 24.04 LTS, créée sur le nœud pve-ha-01 du cluster Proxmox. Le dimensionnement (2 vCPU, 2 Go de RAM, 20 Go de disque) est calibré pour les trois services hébergés (WireGuard, Nginx, Authelia), qui sont peu gourmands en ressources mais nécessitent une disponibilité continue.

- Nœud Proxmox : pve-ha-01
- Carte réseau : bridge vmbr1, rattachée au VLAN 20 (réseau SERVICES) afin que la passerelle soit directement joignable depuis l'AD et GLPI
- Stockage : disque qcow2 sur le stockage partagé NAS-PROJET, permettant un éventuel basculement de la VM sur un autre nœud du cluster

L'adressage réseau est configuré en statique pendant l'installation, afin que l'adresse de la passerelle (192.168.20.30) reste stable et corresponde aux règles de pare-feu et aux enregistrements DNS définis par ailleurs :



Configuration IPv4 statique de la VM srv-gw-sec

Le nom de domaine de recherche (resilience.local) est renseigné pour permettre la résolution des noms courts internes, et le serveur DNS pointe vers le contrôleur de domaine (192.168.20.10).

4. Installation et configuration de WireGuard

WireGuard a été retenu pour sa simplicité de configuration, ses performances (chiffrement par paires de clés Curve25519, intégré au noyau Linux) et sa légèreté par rapport à des solutions plus anciennes (OpenVPN, IPsec). L'installation se fait depuis les dépôts officiels Ubuntu :

```
sudo apt update && sudo apt install -y wireguard
```

La sécurité du tunnel repose sur une paire de clés asymétriques par machine (serveur et client). Chaque machine ne révèle jamais sa clé privée ; seule la clé publique est échangée :

```
wg genkey | sudo tee /etc/wireguard/private.key | wg pubkey | sudo tee
/etc/wireguard/public.key
sudo chmod 600 /etc/wireguard/private.key
wg genkey | tee client_private.key | wg pubkey > client_public.key
```

Le fichier de configuration du serveur (wg0.conf) définit l'adresse du tunnel, le port d'écoute et surtout les règles iptables (PostUp / PostDown) qui activent le routage entre l'interface VPN et le réseau local. Le détail de ce fichier, ainsi que la configuration côté client, est disponible dans le document «Scripts de déploiement».

Une fois le fichier renseigné, le tunnel est activé comme un service système classique, démarré automatiquement au boot :

```
sudo systemctl enable --now wg-quick@wg0
sudo wg show
```

La commande `wg show` affiche l'état de l'interface, la clé publique du pair connu et, après une connexion cliente, le volume de données échangées — c'est l'outil de diagnostic principal pour vérifier que le tunnel fonctionne.

4.1. Distribution de la configuration au client

Côté poste nomade (Windows 10 dans cette réalisation), le client officiel WireGuard est installé puis un tunnel est créé manuellement à partir d'un fichier de configuration vide, complété avec la clé privée générée localement, l'adresse IP attribuée côté VPN (10.0.0.2/24) et les informations du pair serveur (clé publique, endpoint, réseaux autorisés).

- La clé publique du client doit être ajoutée à la section [Peer] du fichier wg0.conf du serveur avant que la connexion ne puisse s'établir.
- Le paramètre Endpoint correspond à l'adresse IP publique (WAN) de pfSense, et non à l'adresse interne de srv-gw-sec.

5. Stack applicative (Docker, Nginx Proxy Manager, Authelia)

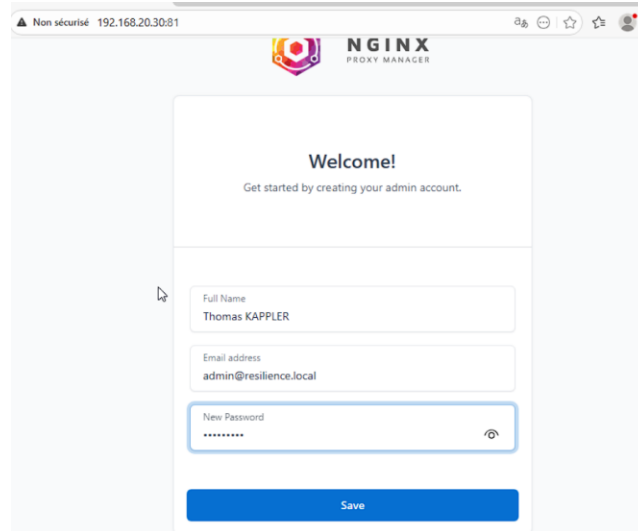
Les services applicatifs (reverse proxy et portail MFA) sont déployés sous forme de conteneurs Docker plutôt qu'installés directement sur le système hôte. Cette approche isole chaque service dans son propre environnement, simplifie les mises à jour de version et permet de reproduire facilement la stack sur un autre serveur si nécessaire.

```
sudo apt install -y docker.io docker-compose
sudo systemctl enable --now docker
mkdir -p /opt/nomad/authelia && cd /opt/nomad
```

Le fichier `docker-compose.yml` (détaillé dans le document «Scripts de déploiement») décrit deux services : `nginx-proxy-manager`, qui expose les ports 80, 443 et 81 (interface d'administration), et `authelia`, qui expose le port 9091 utilisé pour la vérification d'authentification. Le démarrage de la stack se fait en une seule commande :

```
cd /opt/nomad && sudo docker-compose up -d
sudo docker-compose ps
```

Le premier accès à l'interface de Nginx Proxy Manager (port 81) impose la création d'un compte administrateur, qui remplace les identifiants par défaut fournis par l'image Docker :



Initialisation de Nginx Proxy Manager (premier accès, port 81)

5.1. Publication de GLPI et du portail Authelia

Deux Proxy Hosts sont créés dans Nginx Proxy Manager afin de publier les services internes sous des noms de domaine internes, avec un certificat SSL associé :

- Proxy Host glpi.resilience.local → 192.168.20.20:80 (scheme http, GLPI/Apache n'écoulant qu'en clair en interne)
- Proxy Host auth.resilience.local → 192.168.20.30:9091 (scheme https, Authelia étant configuré pour écouter en TLS — voir section 7)

Pour que ces noms soient résolus par les postes du domaine, un enregistrement DNS de type A est ajouté dans la zone resilience.local sur le contrôleur de domaine SRV-AD-01, pointant vers l'adresse de la passerelle (192.168.20.30) :

Création de l'enregistrement DNS auth.resilience.local sur SRV-AD-01

La même opération est répétée pour `glpi.resilience.local`. Sans ces enregistrements, les postes du domaine ne pourraient pas résoudre les noms internes utilisés par le reverse proxy.

6. Certificat SSL interne

Les applications étant publiées en HTTPS, un certificat doit être présenté par le reverse proxy. En l'absence de nom de domaine public, un certificat auto-signé est généré localement avec une validité étendue (10 ans) et un nom commun de type wildcard, couvrant tous les sous-domaines internes :

```
openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -sha256 -days 3650 \
-nodes -subj "/C=FR/ST=France/L=Paris/O=Resilience/CN=*.resilience.local"
```

Ce certificat est ensuite importé comme «Custom SSL Certificate» dans Nginx Proxy Manager et appliqué aux deux Proxy Hosts (`glpi.resilience.local` et `auth.resilience.local`), avec les options Force SSL et HTTP/2 Support activées.

Un certificat auto-signé n'étant pas reconnu par défaut par les navigateurs, il est distribué aux postes du domaine via une stratégie de groupe (GPO), évitant ainsi les alertes de sécurité lors de la navigation vers les applications internes :

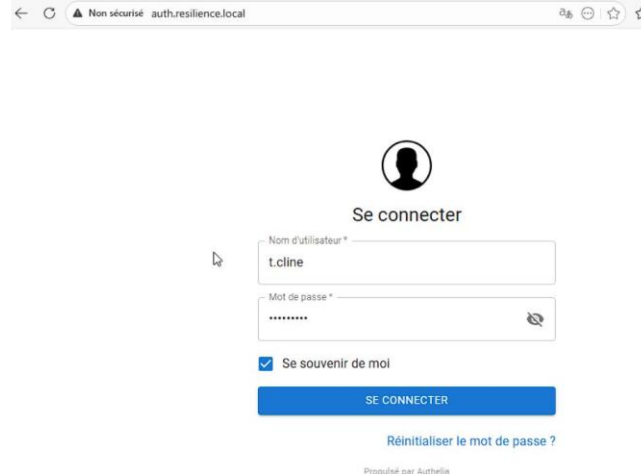
- Le certificat public (`cert.pem`) est exporté au format `.crt` et placé dans une GPO dédiée (`GPO_Deploy_Certificat_SSL`)
- Chemin GPO : Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Stratégies de clé publique > Autorités de certification racines de confiance
- Une fois la GPO liée au domaine, une mise à jour de stratégie (`gpupdate /force`) sur le poste client suffit à propager le certificat sans action de l'utilisateur

7. Authentification Multi-Facteurs et SSO vers GLPI

Authelia constitue le cœur de la sécurisation des accès. Il est lié à l'Active Directory de la réalisation Resilience-IT via le protocole LDAP, en utilisant le compte de service `svc-authelia` (lecture seule sur l'annuaire), ce qui évite de dupliquer la gestion des comptes utilisateurs entre les deux réalisations.

- Premier facteur : mot de passe Active Directory de l'utilisateur, vérifié directement auprès du contrôleur de domaine
- Second facteur : code TOTP (Time-based One-Time Password) à 6 chiffres, généré par une application mobile (Google Authenticator, Microsoft Authenticator ou FreeOTP) lors d'un enrôlement initial par QR Code
- Politique d'accès : `default_policy` à «deny», avec une exception «bypass» pour le portail lui-même et «two_factor» pour `glpi.resilience.local`

Le portail de connexion d'Authelia constitue le point de passage obligatoire avant tout accès aux applications protégées :



Portail de connexion Authelia (auth.resilience.local)

Une fois les deux facteurs validés, Authelia transmet l'identité de l'utilisateur authentifié au reverse proxy via des en-têtes HTTP, eux-mêmes relayés vers GLPI (en-tête REMOTE_USER). GLPI, configuré pour faire confiance à cet en-tête, connecte alors automatiquement l'utilisateur sans lui demander à nouveau ses identifiants : c'est le principe du SSO (Single Sign-On).

La procédure détaillée d'enrôlement du second facteur (captures d'écran, scan du QR Code, validation du premier code) est disponible dans le «Guide utilisateur MFA», destiné aux utilisateurs finaux.

8. Vérification du fonctionnement

La mise en service de la réalisation a fait l'objet de plusieurs vérifications successives, couvrant chaque couche de l'architecture (réseau, applicatif, sécurité) :

- Tunnel VPN : connexion depuis un poste Windows externe au réseau de l'entreprise ; l'état du tunnel et l'échange de paquets sont confirmés côté serveur par la commande `wg show`, qui affiche un volume de données reçues et envoyées non nul pour le pair client
- Résolution DNS interne via le tunnel : depuis le poste connecté en VPN, la commande `nslookup glpi.resilience.local` renvoie correctement l'adresse 192.168.20.30, confirmant que le DNS interne est bien atteint au travers du tunnel
- Accès web : la navigation vers `https://glpi.resilience.local` déclenche une redirection automatique vers le portail Authelia (auth.resilience.local), avec un certificat SSL accepté par le poste grâce à la GPO de distribution
- Authentification : saisie du mot de passe Active Directory (premier facteur), puis saisie du code TOTP affiché par l'application mobile (second facteur)
- SSO : après validation du second facteur, l'utilisateur est automatiquement redirigé vers l'interface GLPI et reconnu sans nouvelle saisie d'identifiants, confirmant la bonne transmission de l'en-tête REMOTE_USER
- Haute disponibilité : un test d'arrêt du nœud Proxmox hébergeant les VM AD/GLPI a confirmé le basculement automatique des services vers un autre nœud du cluster, sans rupture durable de l'accès via la passerelle Nomad-Security

L'ensemble de ces vérifications confirme que les trois objectifs de la réalisation sont atteints : confidentialité des accès distants (VPN), sécurisation renforcée par double authentification (MFA), et continuité de l'expérience utilisateur grâce au SSO vers les applications métier.